

Staying Secure: Cyber Resilience in the NHS

Nasser Arif

Cyber Security Manager

London Northwest University Healthcare NHS Trust

Hillingdon Hospitals NHS Foundation Trust



London North West
University Healthcare
NHS Trust



The Hillingdon Hospitals
NHS Foundation Trust

**Should we
fear cyber
security?**



Why should NHS staff care?

- Life or death healthcare situations more important..
- Mandatory training ticks the compliance box already?
- Cyber security only matters at work?

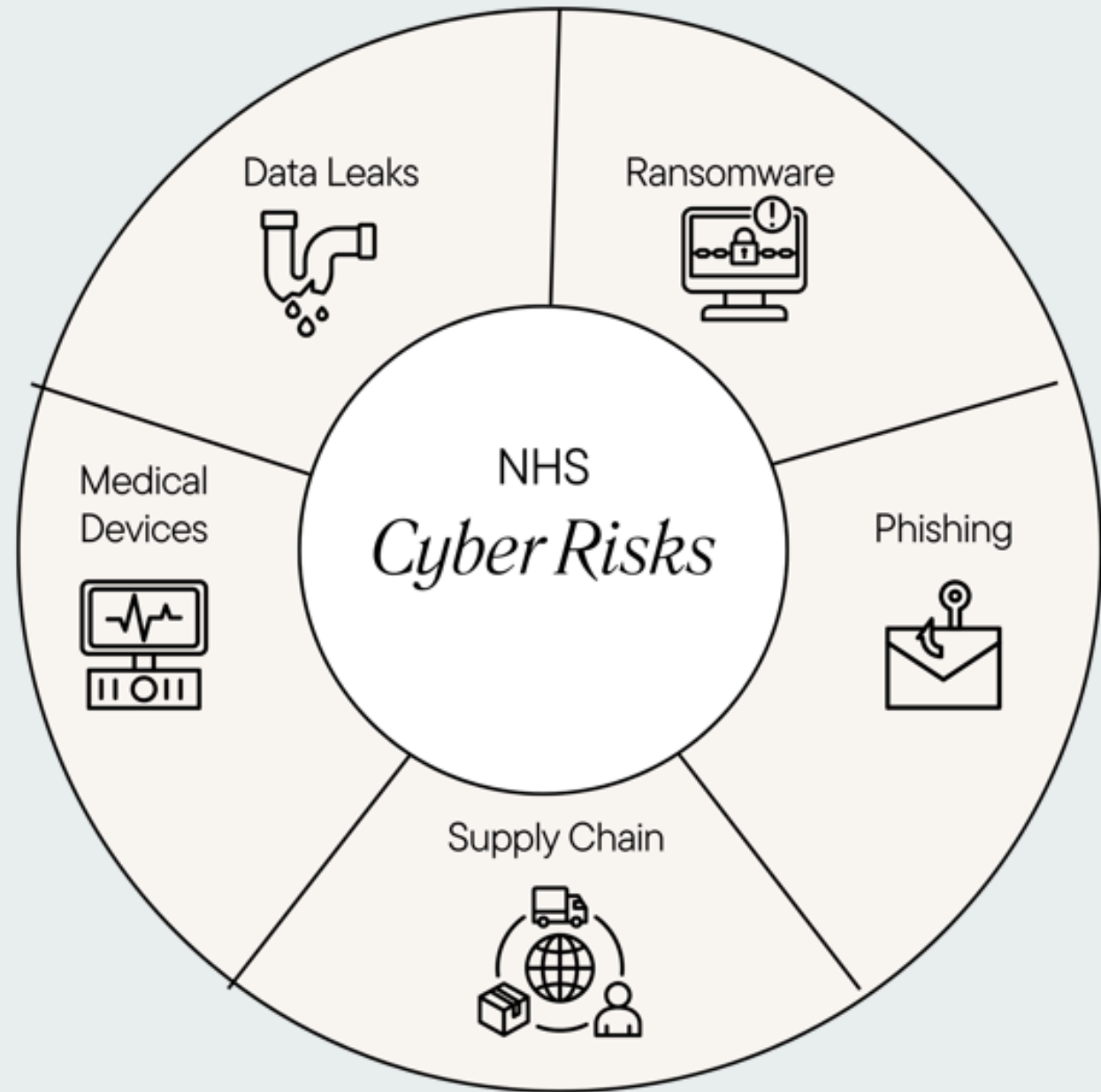
“We have the IT department to look after cyber security, so why should we care?”



**What
are the
threats?**



Typical NHS Cyber Risks



Medical Device Risks

- Legacy devices still around.
- System complexity.
- Not always secure by design.
- Vulnerabilities being exploited by threat actors.
- Departments may require more investment to replace these older systems.



Supply Chain Risks

- Suppliers are an active target.
- Suppliers need to REMAIN compliant.
- Are new systems secure by design?
- [Cyber security charter for suppliers to the NHS - NHS England Digital](#)
- [Cyber Security and Resilience Bill - GOV.UK](#)



The screenshot displays the NHS England Digital website. At the top is the NHS England logo. Below it is a navigation bar with 'Digital' as the active section, and links for 'Services', 'Data', 'Cyber', 'Developer', 'News', and 'A'. A breadcrumb trail reads: 'NHS Digital > Cyber and data security > Guidance and assurance > Cyber security charter for suppliers to the NHS'. The main heading is 'Cyber security charter for suppliers to the NHS', followed by the subtitle 'A commitment from technology suppliers to the health and social care system.' Below this, there are two columns. The left column, titled 'Page contents', contains links: 'Top of page', 'Your commitment', 'What we offer in return', and 'Background'. The right column, titled 'Your commitment', contains the text 'Current and potential IT suppliers to the NHS should commit' followed by a numbered list: '1. Our systems are kept in support and have the latest patch' and '2. We will achieve and maintain at least 'Standards Met' as per (DSPT).²'.

NHS
England

Digital Services Data Cyber Developer News A

NHS Digital > Cyber and data security > Guidance and assurance > Cyber security charter for suppliers to the NHS

Cyber security charter for suppliers to the NHS

A commitment from technology suppliers to the health and social care system.

Page contents

- [Top of page](#)
- [Your commitment](#)
- [What we offer in return](#)
- [Background](#)

Your commitment

Current and potential IT suppliers to the NHS should commit

1. Our systems are kept in support and have the latest patch
2. We will achieve and maintain at least 'Standards Met' as per (DSPT).²

Phishing follows us home!

E-mail Phishing

Voice Phishing
(Vishing)

SMS /
Messenger
Phishing
(Smishing)

QR Code
Phishing
(Quishing)

Spear Phishing
(specific
targets)

Whaling (high
profile targets)



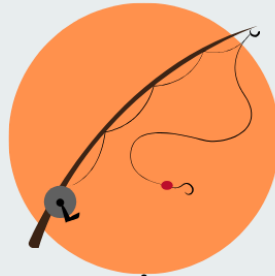
THE LURE

Something that grabs your attention – often using a false sense of urgency!



ACTION

Clicking a link, downloading a malicious app / file, handing over passwords and more!



END GAME

The attackers end goal is achieved. Data theft, ransom or worse!



THE HOOK

This could be a fake but realistic looking website, phishing link, convincing phone call or more!

INFECTION / DATA EXFILTRATION

Malware infection, credential harvesting or other actions on objectives!

Phishing Email Example

Sense of Urgency

Fw: Action required – your NHSmail account has been set as a 'Leaver'

Referencing
known NHSmail
features

 If there are problems with how this message is displayed, click here to view it in a web browser.

Subject: Action required – your NHSmail account has been set as a 'Leaver'

NHSmail - Important Information

Subtle grammar
error – capital M
missing

Action required Your NHSmail account has been set as a 'Leaver'

Using threats and
fear tactics

Suspicious link –
identified only when
hovering over it with
mouse cursor

Dear NHSmail user

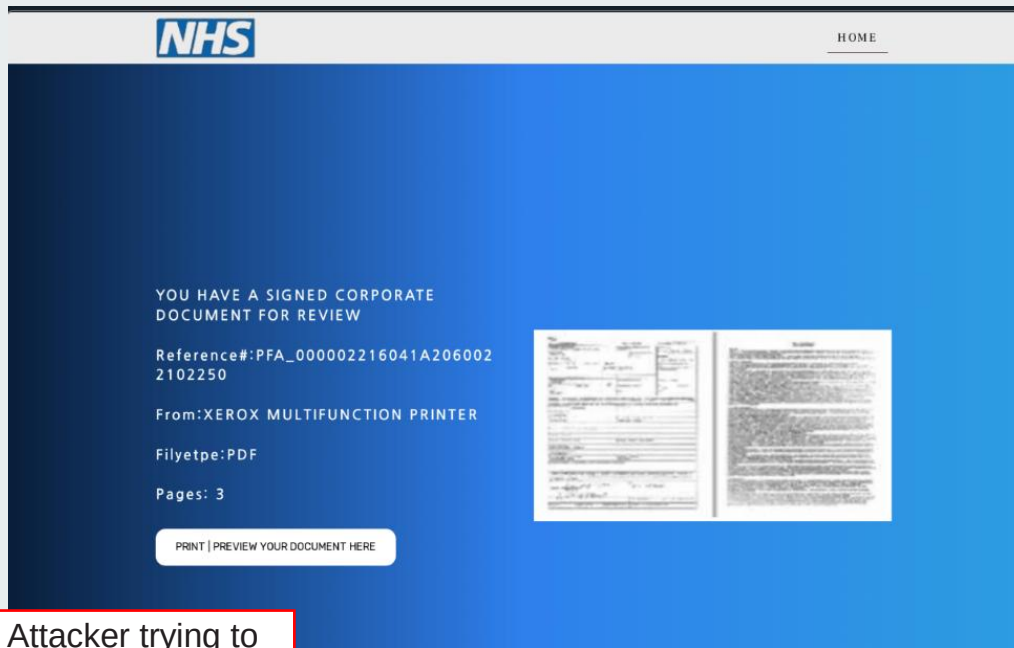
Your account has been marked as a Leaver by your Local Administrator (LA). Typically, this occurs when a user leaves employment with an NHS / health and care organisation or when a user leaves employment with a partner organisation. <https://info-file76445695.mybigcommerce.com/>

Access your profile [Click or tap to follow link.](#) now:

<https://portal.nhs.net/Profile>

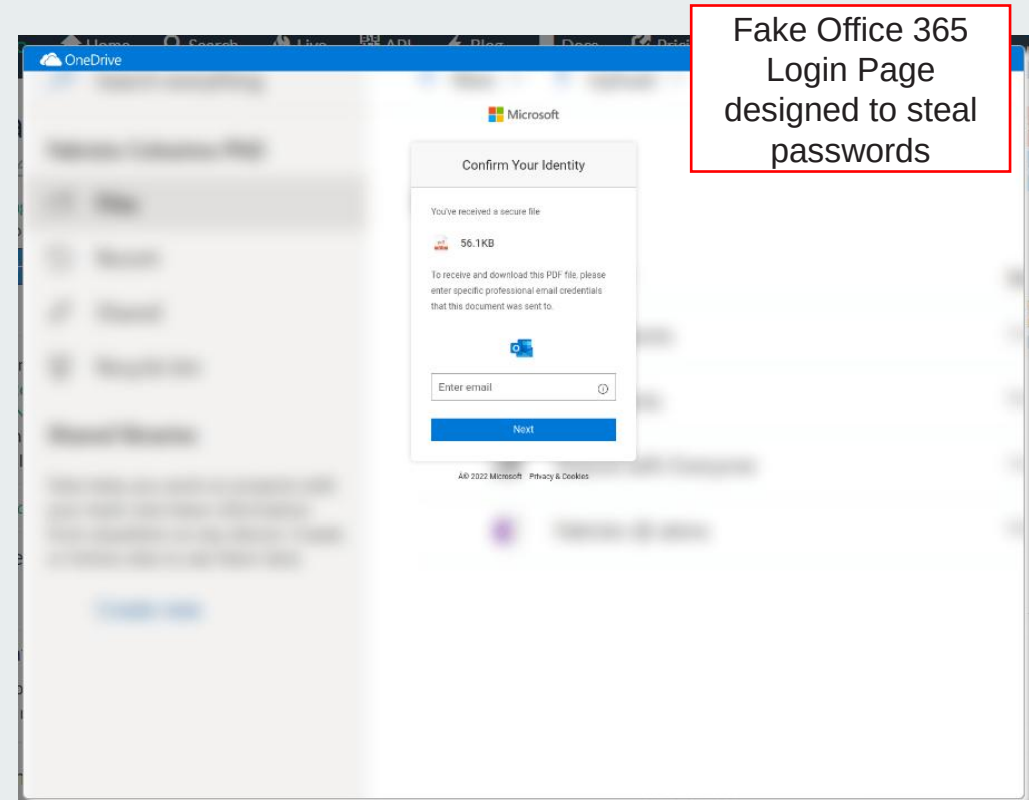
What happens if you click the link?

Stage 1: Initial Phishing Landing Page



Attacker trying to use NHS style – indicates targeted Phishing campaign

Stage 2: Credential Harvester



Fake Office 365 Login Page designed to steal passwords

Vishing – Phone Call Scams

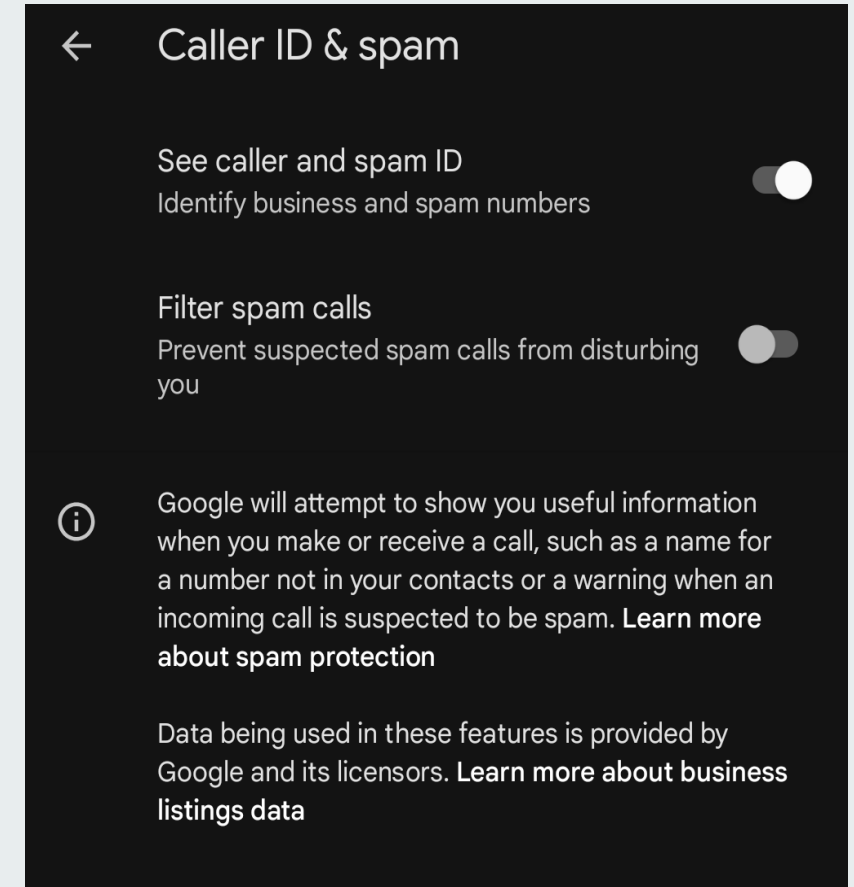
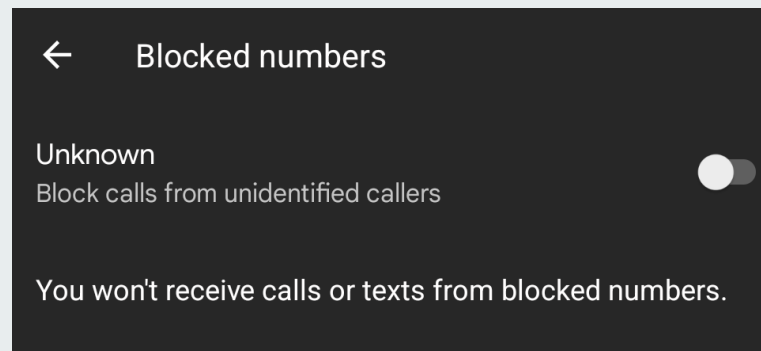
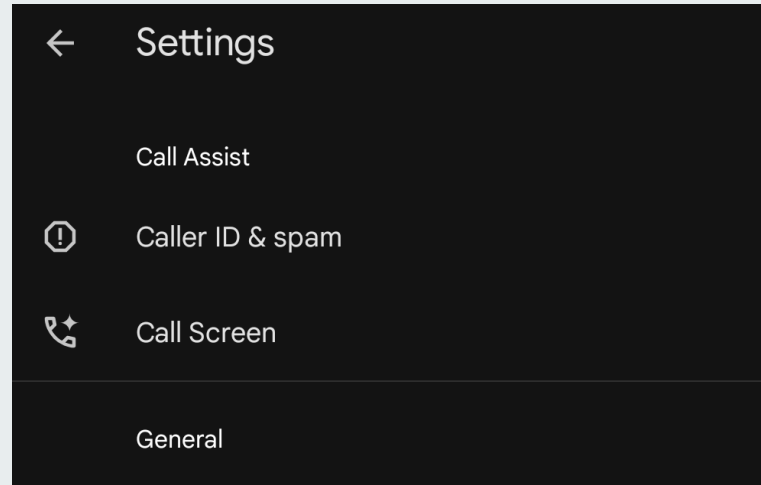
- Never hand over sensitive data on the phone!
- Call the service directly, using a trusted number to verify authenticity.
- Don't fall for the false sense of urgency!

**IGNORING A SCAM PHONE
CALL LIKE....**



Android – Use Caller ID / Spam Protection

- Ensure these features are turned on.
- Utilises Google database to detect spammers (highly effective)



Apple – Detect and Block Spam Calls



Silence unknown callers (use wisely – can prevent phone calls too)

Silence Junk Callers – Settings / Apps / Phone / Call blocking / Silence junk callers *(depends on IOS version and carrier)*

Note: Call identification requires third party apps.

Data Leaks - Public Wi-fi Risks

- Man in the middle attacks.
- Data loss / leakage.
- Malicious hotspots disguised as legitimate ones – ‘Evil Twins’
- Loss of privacy (browsing history, metadata etc).
- Malware spread.

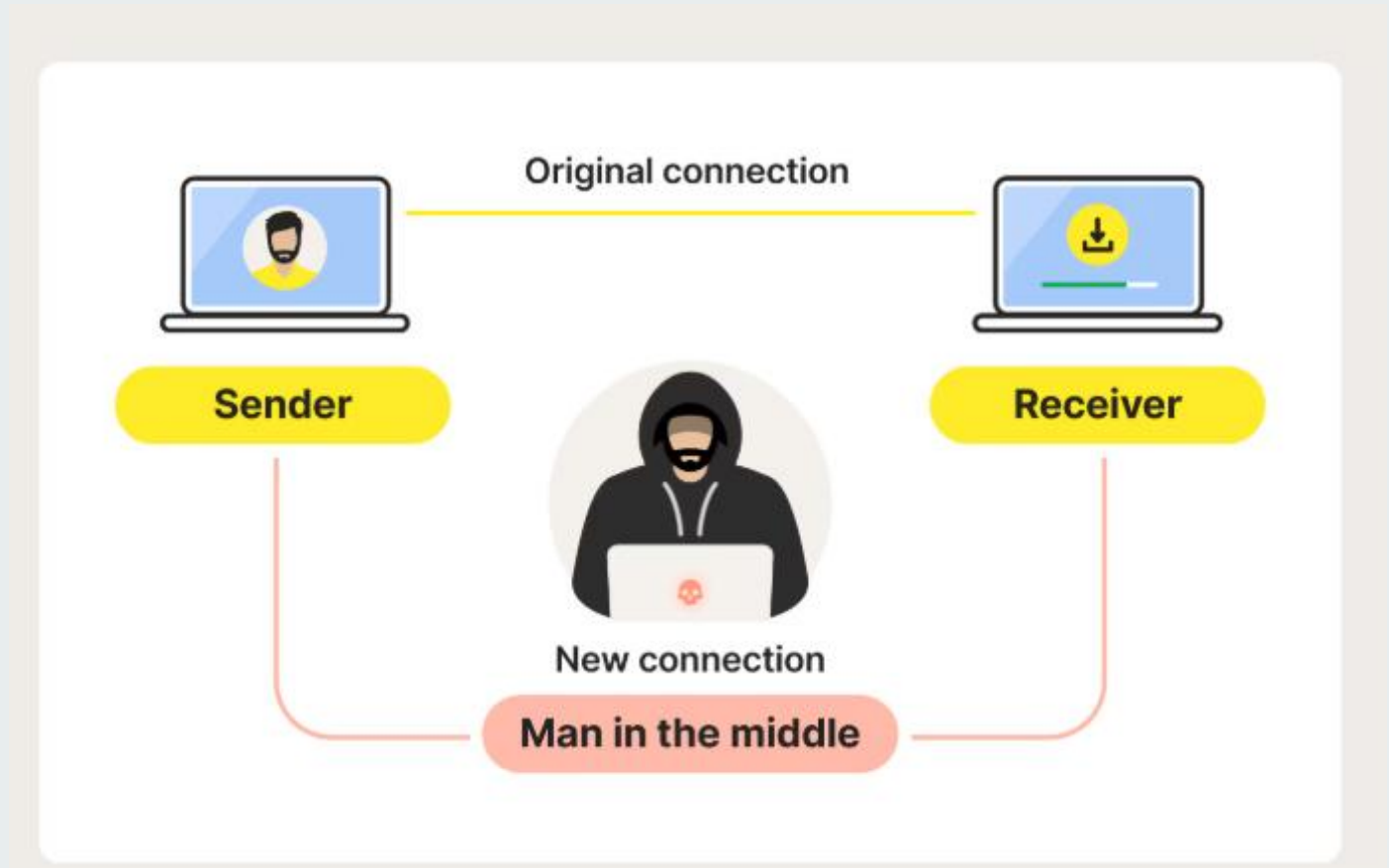


Image source: Norton

Don't expose yourselves in public!

- Use a VPN to protect your connection.
- Only visit HTTPS sites (look for the padlock),
- Use MFA apps.
- Don't perform any sensitive tasks on public Wi-Fi.



Finding your inner cyber defender!



Keep devices up to date!

Apple Patches Major Security Flaws in iOS, macOS Platforms

New iPhone Security Flaw Exposes Billions of Users to Potential Hacking

Android fixes 47 vulnerabilities, including one zero-day. Update as soon as you can!

Android Update Patches FreeType Vulnerability Exploited as Zero-Day

Google Confirms Android Attacks—Millions Of Samsung Phones Need Update

Password Hygiene

Passwords prevent unauthorised access to our sensitive data.

- Use at least 10-12 characters; including Upper- and lower-case letters, a number and a special character.
- Do not use your name, nickname, initials, username or other known info.
- Consider using three random words or even a passphrase.

Keep passwords unique and never share them!



Your passphrase score: **strong**

Estimated time to crack: **centuries**

Atrocious4-Theft-Creation



 Copy to clipboard

 Regenerate

Type

☐ Password ☒ Passphrase

Additional options

☒ Capitalize ☒ Include number Word separator 

Want to test the strength of another passphrase or password? [Try the Bitwarden Password Strength Testing Tool.](#)

Image Source: Bitwarden Password Generator

E-mail #1: The 'Skeleton Key' of online accounts

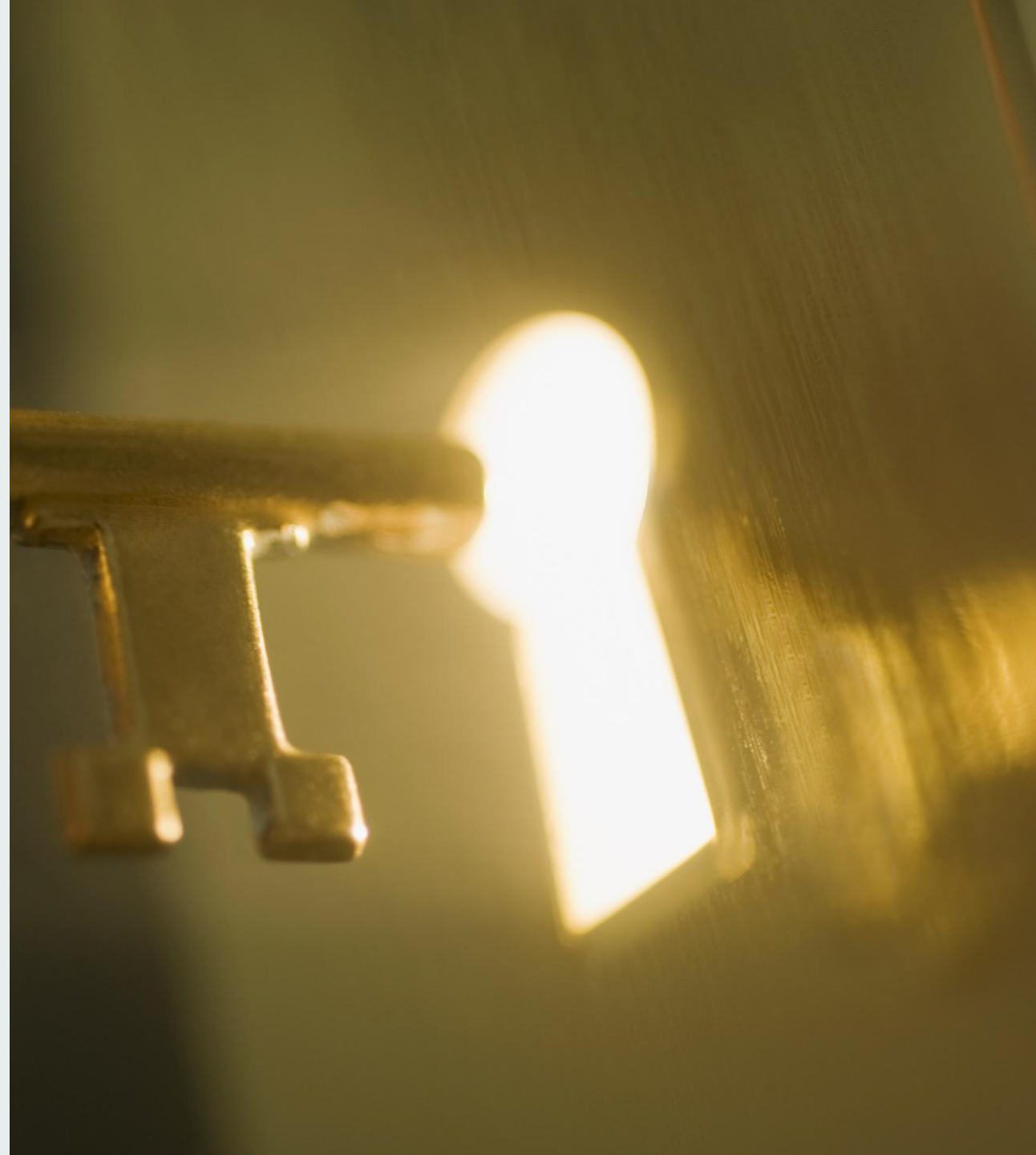
Backbone of all our online accounts.

Both work and personal accounts
must be protected.

Gateway to your digital identity.

Often used to breach online
banking, social media and work
accounts.

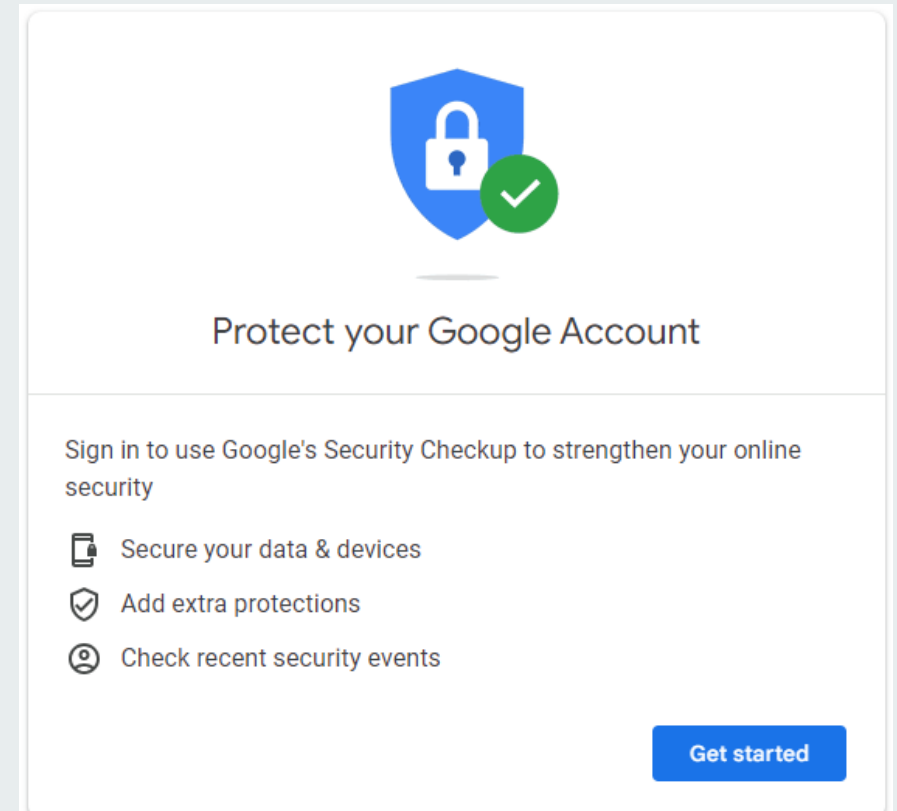
Used by threat actors for
persistence.



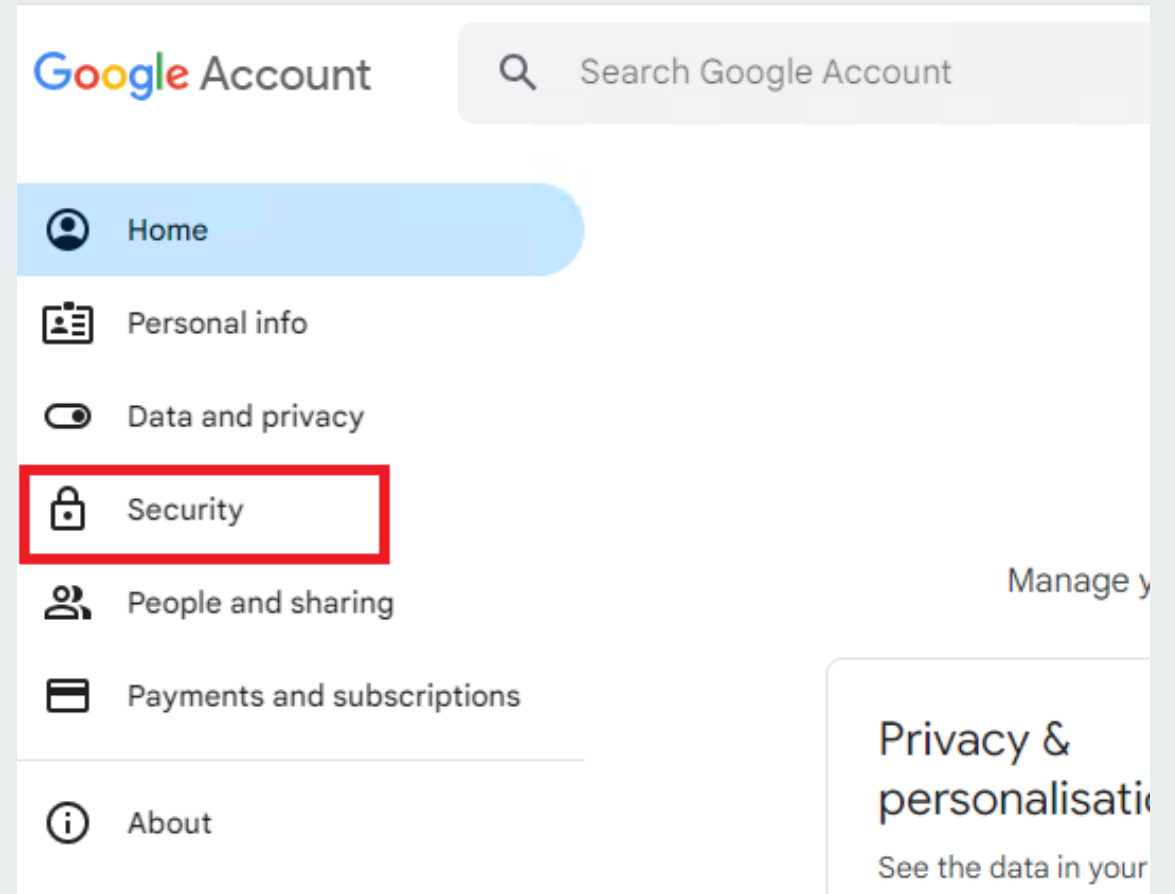
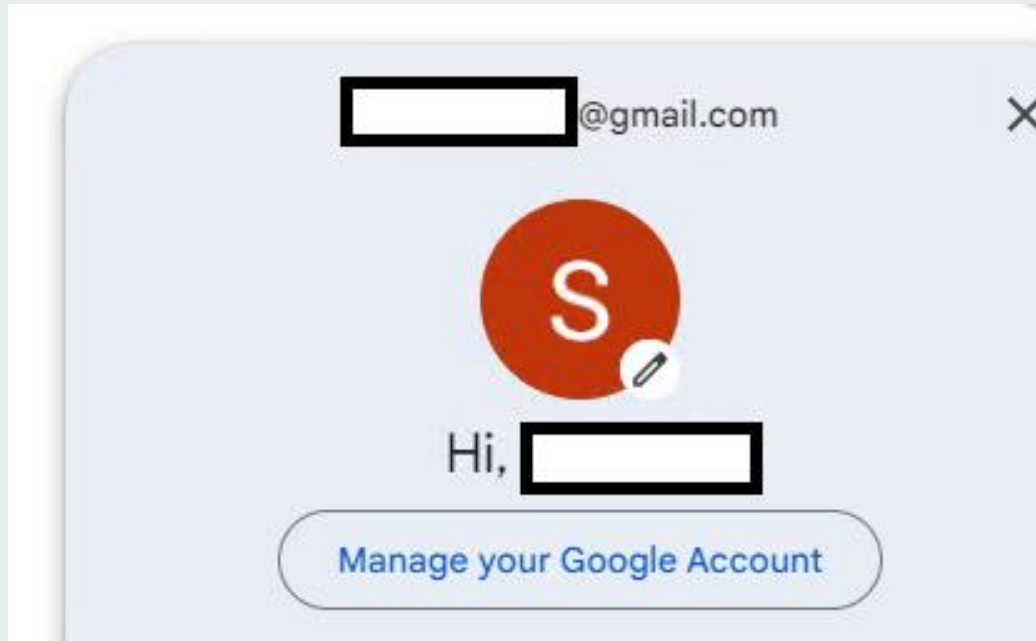
E-mail #2: Security Check-ups

Protect your personal email accounts by:

- Performing monthly security audits of your email accounts.
- Enable Multifactor Authentication (MFA).
- In your personal life, consider using multiple email addresses for different services (especially for recovery emails).
- Use unique / complex passwords.
- Look out for phishing emails and suspicious links / attachments.



Example: Gmail #1



Example: Gmail #2



Security Check-Up

You have recommended actions

	Sign-in and recovery Add ways to verify that it's you	▼
	Safe Browsing Turn on Enhanced Safe Browsing	▼
	Your devices Where you're signed in	▼
	Recent security activity No activity in the last 28 days	▼

[Continue to your Google Account](#)

Example: Gmail #3

How you sign in to Google

Make sure that you can always access your Google Account by keeping this information up to date

 2-Step Verification	2-Step Verification is off	>
 Password	Last changed 1	>
 Skip password when possible	 On	>
 Recovery phone	 Add a mobile phone number	>
 Recovery email	 Add an email address	>

You can add more sign-in options

 Passkeys and security keys

 Authenticator

 Google prompt

 2-Step Verification phone

Google and Apple Account Security

- Use unique, complex passwords.
- Regularly review activity.
- Enable multifactor authentication (MFA) as soon as possible!
- Keep recovery details private.
- Ideally use MFA apps instead of SMS!
- **Remember what these accounts have access to. (Protect them)**



Image Source: Android

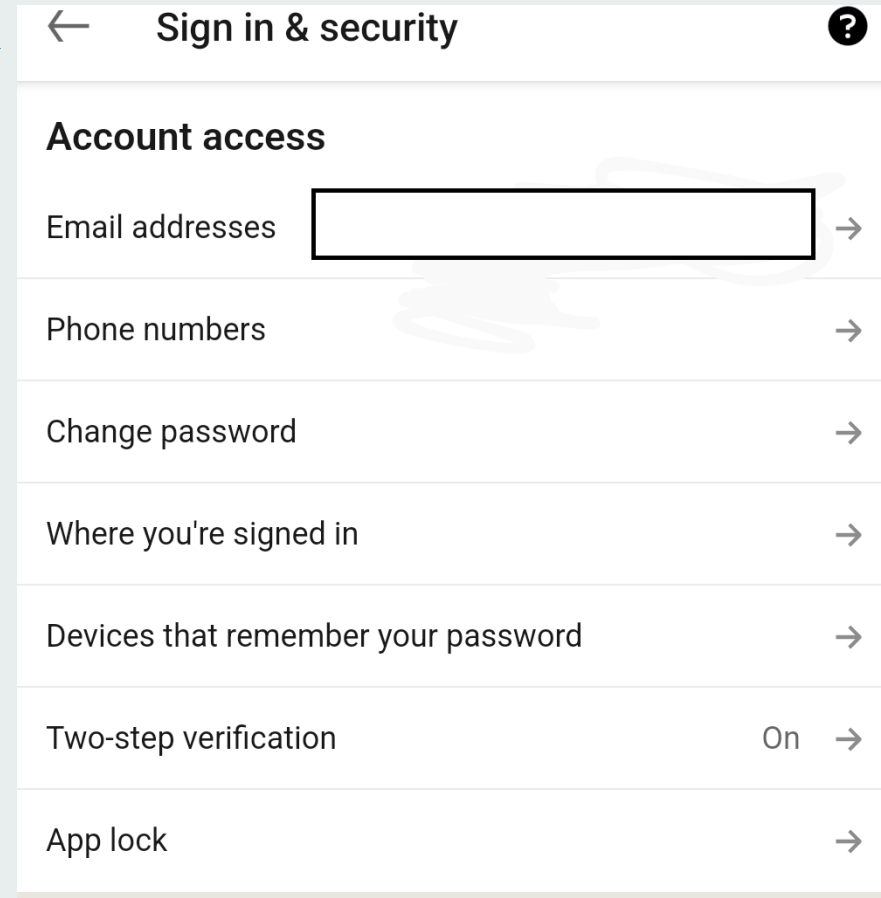
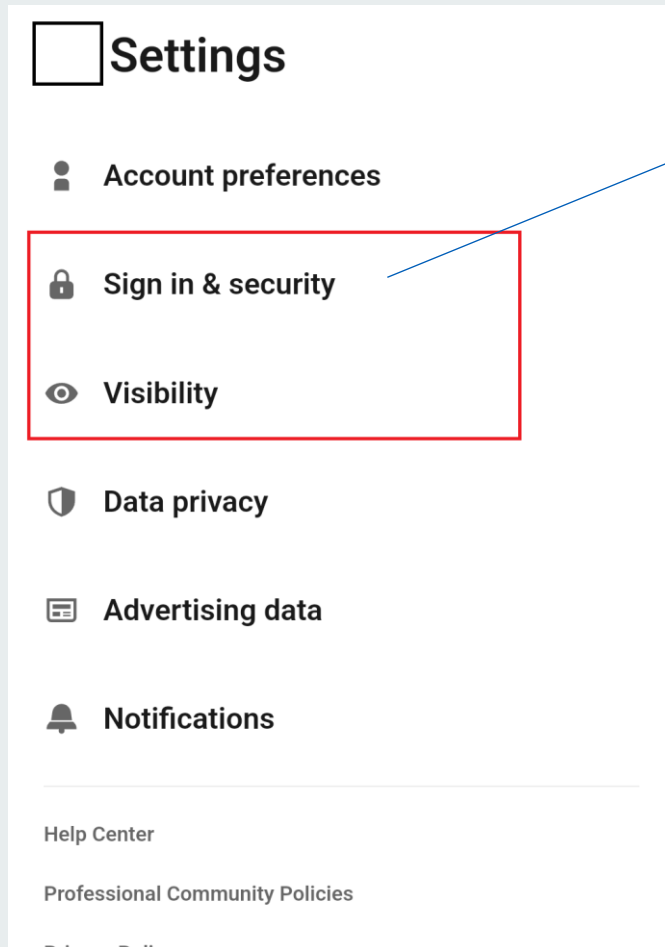
Social Media: Sharing is not always caring!

Social media risks include:

- Oversharing of personal sensitive data without even realising it.
- **Think about what you are sharing and who has access to it.**
- Phishing and Scams.
- Reputational damage.
- Helping threat actors build a full picture of your life. **Maintain control.**



LinkedIn Lockdown #1: Security Settings

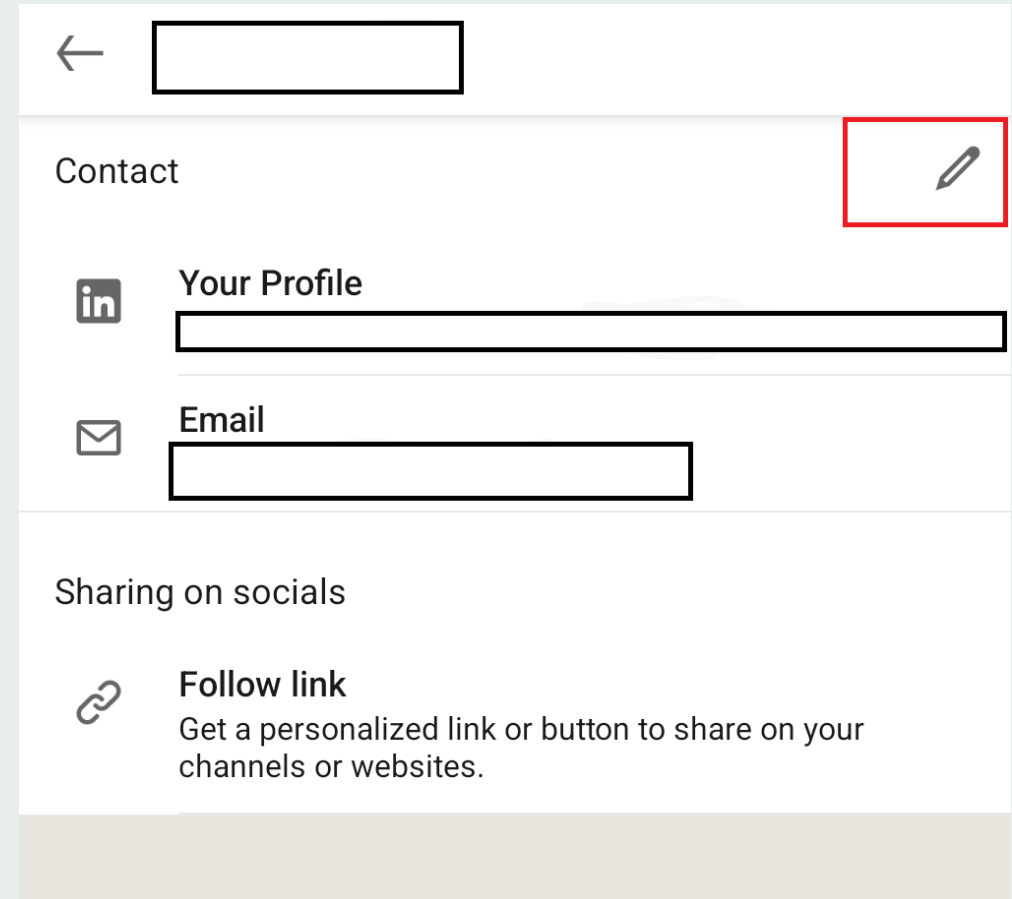
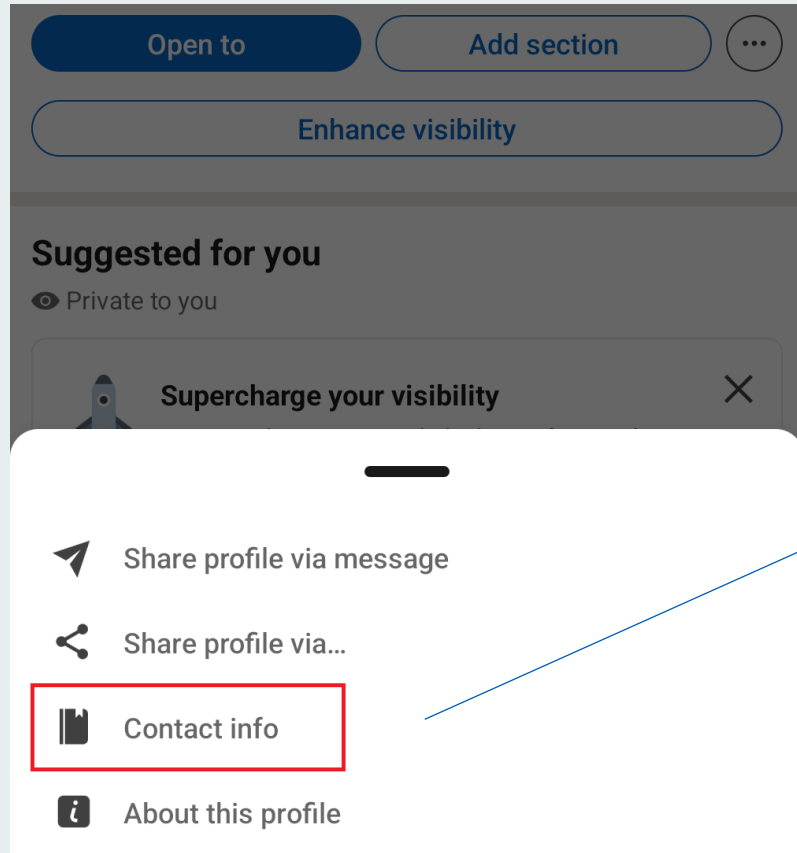


LinkedIn Lockdown #2: Email Visibility

The image illustrates the steps to adjust email visibility on LinkedIn through three sequential screenshots:

- Settings Menu:** The 'Settings' page is shown with a sidebar containing 'Account preferences', 'Sign in & security', 'Visibility', 'Data privacy', 'Advertising data', and 'Notifications'. The 'Visibility' option is highlighted with a red box, and a blue arrow points to the next screenshot.
- Visibility Settings:** The 'Visibility' settings page is shown with a list of options: 'Profile viewing options', 'Page visit visibility', 'Edit your public profile', and 'Who can see or download your email address'. The last option is highlighted with a red box, and a blue arrow points to the final screenshot.
- Email Visibility Options:** The 'Email visibility' settings page is shown with the question 'Who can see [redacted] on your profile or in approved apps?'. Four radio button options are listed: 'Only visible to me' (selected), '1st degree connections', '1st and 2nd degree connections', and 'Anyone on LinkedIn'.

LinkedIn Lockdown #3: Birthday



LinkedIn Lockdown #4: Visibility

 **Off-LinkedIn Visibility** 

Show information from your profile to users of permitted services such as Outlook?
[Learn more](#)

Profile visibility outside LinkedIn Off 

 **Visibility** 

Visibility of your profile & network

Profile viewing options 

Page visit visibility 

Edit your public profile →

Who can see or download your email address →

Who can see your connections Off →

Who can see members you follow Only visible to me →

Who can see your last name →

Representing your organizations and interests  →

Page owners exporting your data  →

Profile discovery and visibility off LinkedIn →

Profile discovery using email address  →

Profile discovery using phone number Nobody →

Blocked members →

Visibility of your LinkedIn activity

Manage active status No one →

Deep Dive: WhatsApp Messenger

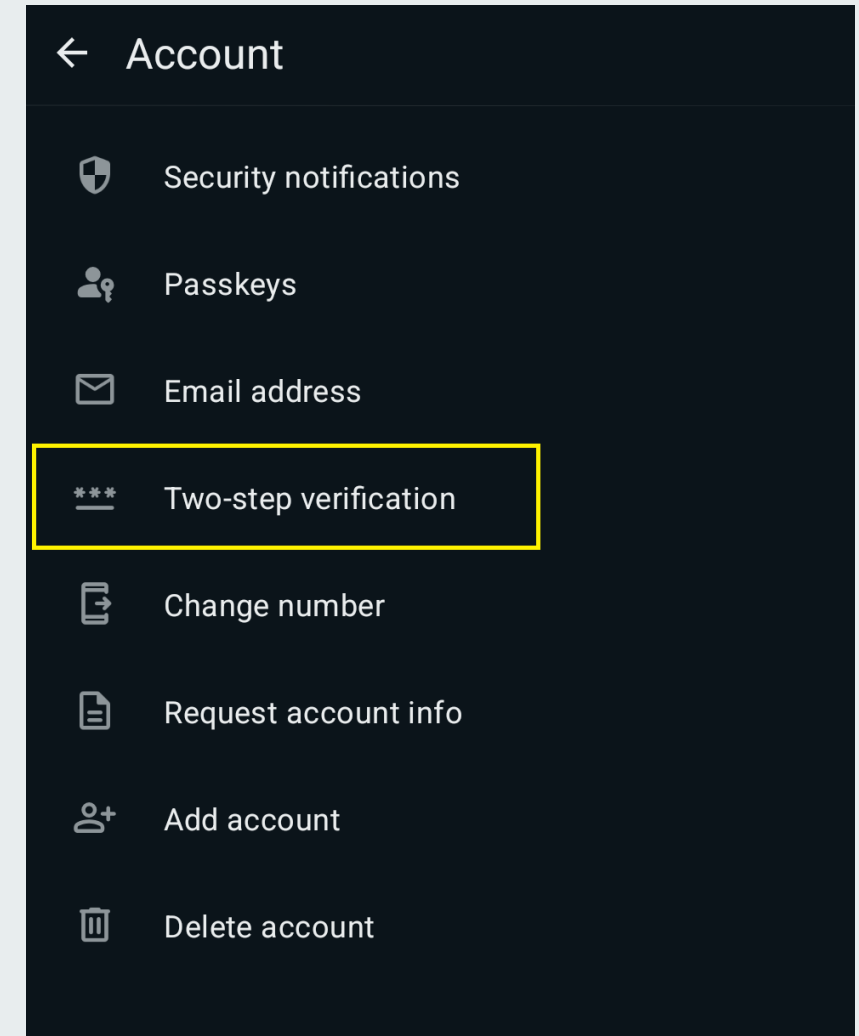
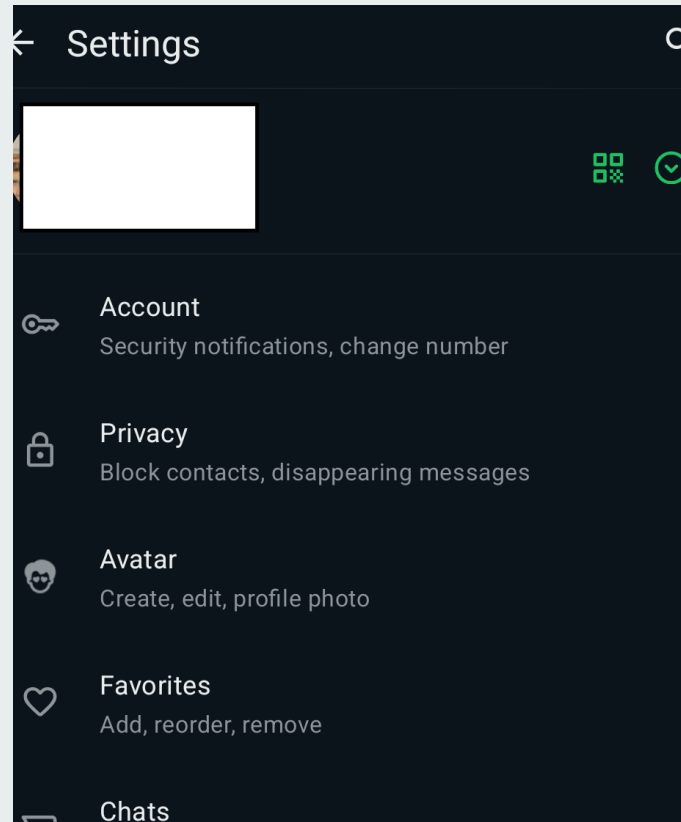
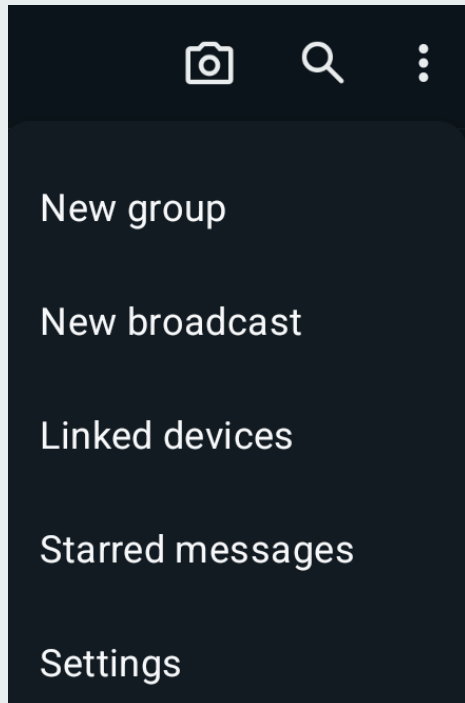


[This Photo](#) by Unknown Author is licensed under [CC-BY-NC-ND](#)

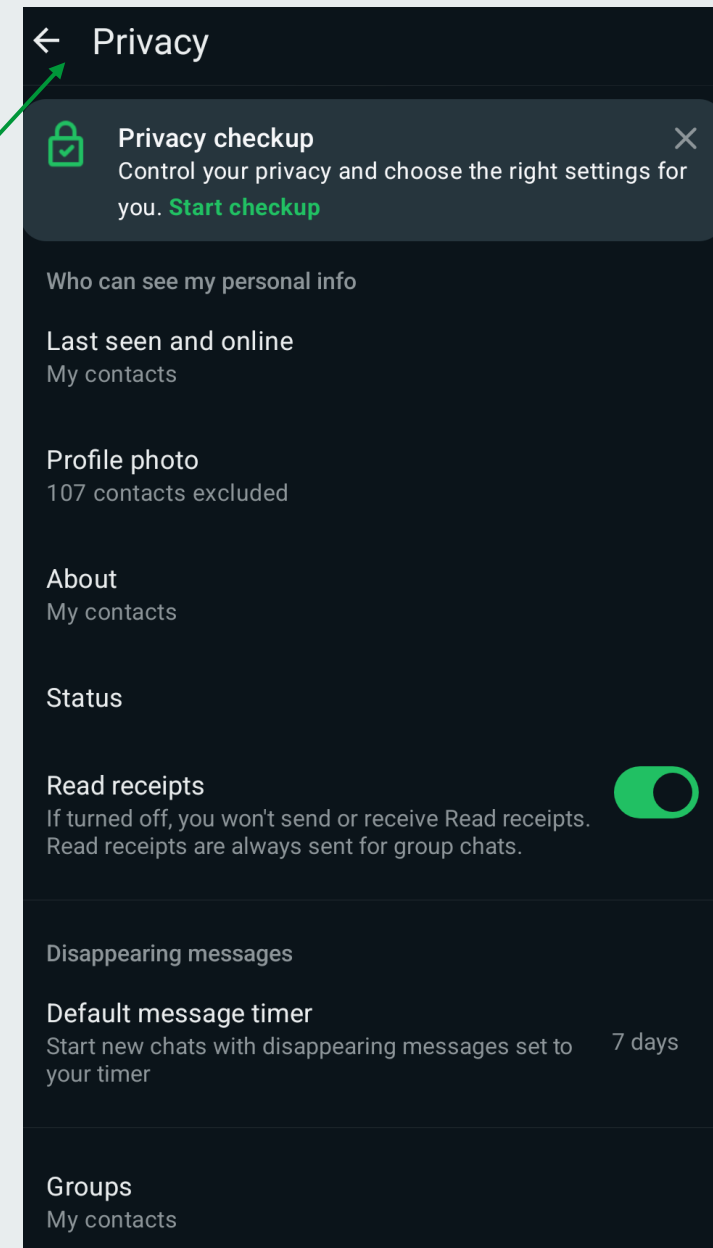
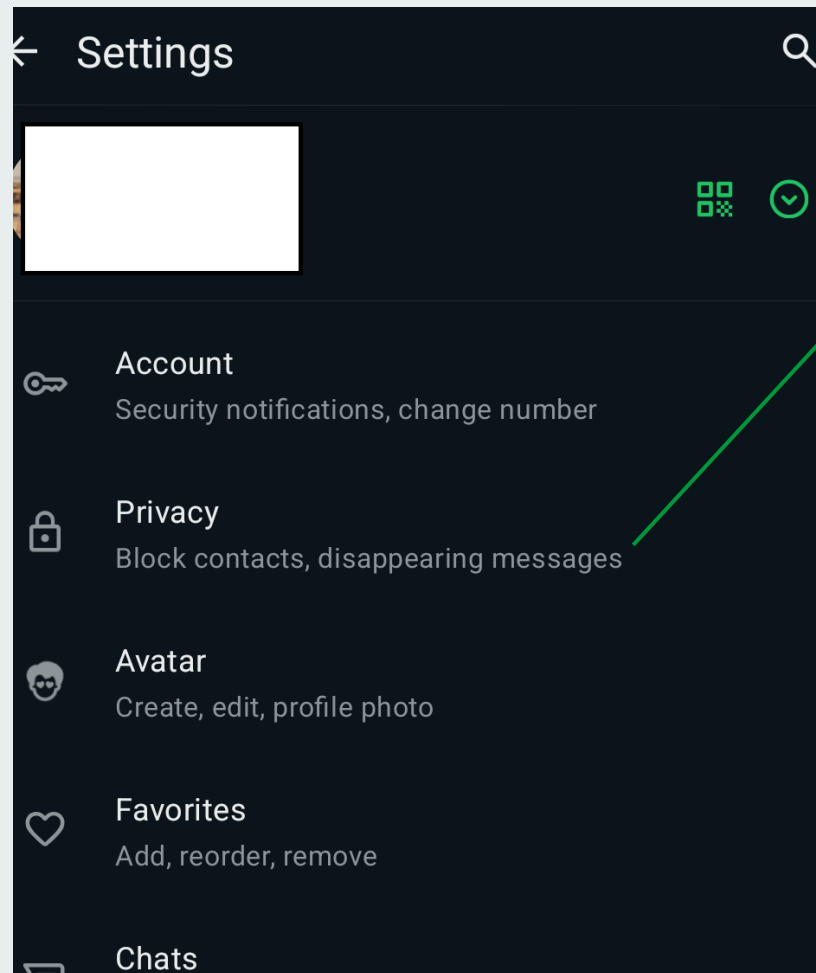
- **FREE TO USE**
- End-to-end encrypted messaging
- Audio and Video calling included.
- Media sharing.
- Synced with phone contacts.
- Built in privacy features.
- Used by businesses and normal consumers.

WhatsApp Best Practice

- Two-step verification / MFA – prevent someone from opening a WhatsApp account using your number.

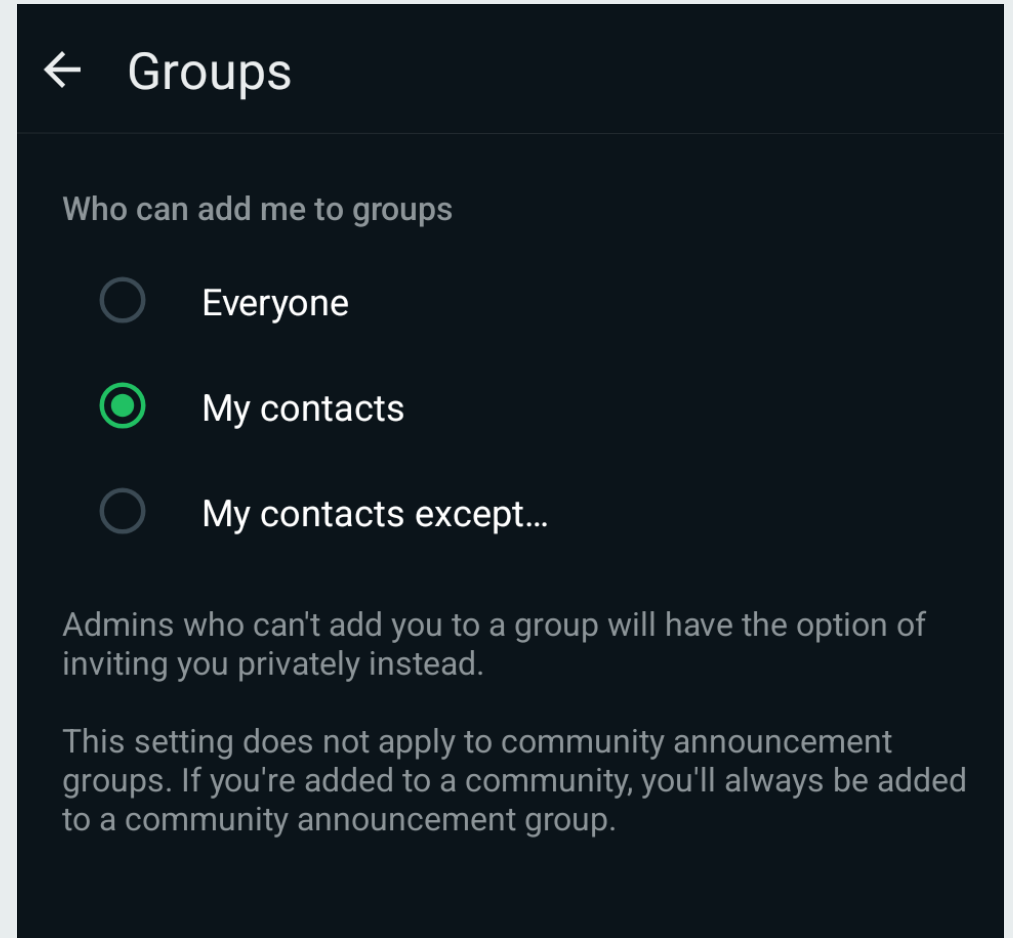


WhatsApp: Privacy



WhatsApp: Group Controls

- Stop random people from adding you to WhatsApp groups.
- Groups are often abused by spammers.
- Ensure only trusted contacts can create groups with you.



Multifactor Authentication (MFA)

- Provides an additional layer of security.
- SMS no longer ideal – consider authenticator apps instead.
- Find this setting in your apps.
- Also known as two-step verification, 2FA, 2SV.



Key Takeaways

- Keep devices up to date!
- Protect your core accounts (email, appleid, google, banking, messengers).
- Use MFA everywhere you can.
- Unique passwords.
- Maintain control over what you share online.
- Regular reviews of your own accounts.
Privacy settings are great.
- Do not fear cyber security!



Take time to think before you act!

Scammer: "Can you provide your bank details, password and date of birth?"

You:



Cyber Security Education



Example: ISC2 Certified in Cybersecurity



The image shows a screenshot of the ISC2 website. The header is white with the ISC2 logo on the left and navigation links: 'Get Started', 'Training', 'Certification', 'Continuing Education', and 'Members'. The main content area has a dark blue background with white text. It features a 'LIMITED TIME' tag, followed by the headline 'FREE Entry-level Cybersecurity Training + Certification Exam', and the subtext 'Start your career today!'.

ISC2

[Get Started](#) [Training](#) [Certification](#) [Continuing Education](#) [Members](#)

LIMITED TIME

FREE Entry-level Cybersecurity Training + Certification Exam

Start your career today!

FREE Cybersecurity Education Courses

🕒 5 min. read

Welcome to Palo Alto Networks FREE Cybersecurity Education Courses.

All that is required to take our fundamentals of cybersecurity courses is an email address on Beacon, the Palo Alto Networks education platform.

Create a free Beacon account here: <https://login.paloaltonetworks.com/lms/PreRegister?UserType=CUST>

Get a solid foundation in cybersecurity through four self-paced, online courses.

Catalog > Introduction to Cybersecurity

 Networking
cisco Academy

Course

Introduction to Cybersecurity

This course is part of the **Career Path - Junior Cybersecurity Analyst**

Explore the exciting field of cybersecurity and why cybersecurity is a future-proof career.



Self-Paced Online
Learn online at your own pace



Instructor-Led
Learn with an academy

English (English) ▾

Get Started With Self-Paced

AVAILABLE LANGUAGES

العربية, Bahasa Indonesia, Deutsch, English, Español, Français, Italiano, 日本語, 한국어, Nederlands, Polski, Português, Română, ไทย, Türkçe, Український

Overview

Curriculum

This introductory course takes you inside the world of cybersecurity. You will learn cybersecurity



FREE



6 HOURS



BEGINNER



7 LABS



SELF-PACED

Example: Cisco NetAcad

NHS England – Immersive Labs



Digital

[Services](#)[Data](#)[Cyber](#)[Developer](#)[News](#)[About](#)



[NHS Digital](#) > [Cyber and data security](#) > [Training](#) > [immersive-labs-online-cyber-security-e-learning](#)



Immersive Labs online cyber security e-learning

We're offering health and care colleagues free user licences for Immersive Labs, an innovative cyber security learning platform.

Page contents

[Top of page](#)[Register for a licence](#)[About Immersive Labs](#)[Continuing Professional Education \(CPE\) credits](#)

Register for a licence

Licences are available to everyone working for an NHS organisation. Complete the request form to register.

Complete the request form